



### Práctica #3

Adrian Fajardo Liu  
Rubén Acevedo Rodríguez  
Edgar Luis Alfaro Quiros  
Oscar Chavarría Hernandez  
Mauricio Leiton Rodríguez  
Alejandro Vilorio Valverde

Universidad CENFOTEC

CIB-21 Seguridad de Operaciones

Profesor: Bryan Gerardo Calderón Montero

22 de Septiembre, 2025.

## **Introducción**

Hoy en día la administración de cuentas de usuario es un tema muy importante en la seguridad informática. No importa si hablamos de Windows, Linux o macOS, todos los sistemas operativos incluyen herramientas ya instaladas que ayudan a manejar usuarios, configurar reglas de seguridad y revisar la actividad de quienes ingresan.

El propósito de este trabajo es identificar esas herramientas que ya vienen con cada sistema, aprender cómo se usan y ver de qué manera ayudan a mejorar la protección de la organización. También se busca analizar las diferencias entre cada sistema y reflexionar sobre cuál ofrece más ventajas en este tema.

## Índice

|                                                                                                                                                  |           |
|--------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| <b>Guía de Acciones y Evidencias de Active Directory (TryHackMe Lab)</b>                                                                         | <b>5</b>  |
| Evidencia #1: Usuarios en OU Sales                                                                                                               | 5         |
| Evidencia #2: Eliminación de la OU "Research and Development"                                                                                    | 6         |
| Evidencia #3: Delegación de Control y Restablecimiento de Contraseñas                                                                            | 7         |
| Evidencia #4: Organización de Workstations                                                                                                       | 8         |
| Evidencia #5: Modificación de GPOs (Group Policy Objects)                                                                                        | 9         |
| Evidencia #6: Restricciones y Bloqueo Automático                                                                                                 | 10        |
| Evidencia #7: TryHackMe Completado                                                                                                               | 11        |
| <b>Preguntas</b>                                                                                                                                 | <b>12</b> |
| 1. ¿Cómo influye la estructura organizacional (OUs, dominios, árboles y bosques) en la seguridad y administración de una red corporativa?        | 12        |
| 2. ¿Cómo puede una mala configuración de delegaciones u OUs dejar expuestos permisos sensibles?                                                  | 12        |
| 3. ¿Qué implicaciones de seguridad surgen al usar diferentes métodos de autenticación como Kerberos vs NTLM en Active Directory?                 | 12        |
| 4. ¿Por qué Kerberos es el protocolo preferido hoy en día?                                                                                       | 12        |
| 5. ¿Qué riesgos existen si NTLM sigue habilitado?                                                                                                | 12        |
| 6. ¿Cómo podrían los atacantes aprovechar credenciales o tickets antiguos/vulnerables?                                                           | 12        |
| 7. ¿De qué forma las políticas de grupo (GPOs) y su correcta aplicación pueden afectar tanto la productividad como la seguridad de los usuarios? | 13        |
| 8. ¿Cuándo es beneficioso aplicar políticas muy estrictas vs. políticas más relajadas?                                                           | 13        |
| 9. ¿Qué consecuencias puede tener aplicar una GPO equivocada (o sin pruebas) a un OU?                                                            | 13        |
| <b>Administrador de Directivas de Grupo en Windows</b>                                                                                           | <b>14</b> |
| <b>Herramientas para Deshabilitar Cuentas Predeterminadas o Innecesarias</b>                                                                     | <b>14</b> |
| <b>Políticas de Cuenta y Directivas de Bloqueo de Cuentas</b>                                                                                    | <b>14</b> |
| <b>Auditoría y Monitoreo de Cuentas de Usuario</b>                                                                                               | <b>15</b> |
| <b>Gestión de Cuentas Inactivas</b>                                                                                                              | <b>15</b> |
| <b>Reflexión Final</b>                                                                                                                           | <b>16</b> |
| 1. ¿Qué diferencias notaste en las herramientas disponibles entre los tres sistemas operativos?                                                  | 16        |
| 2. ¿Qué sistema operativo consideras más completo para gestionar y auditar cuentas de usuario? Justifica tu respuesta.                           | 16        |
| 3. ¿Qué otros pasos podrías implementar para complementar la seguridad de las cuentas de usuario?                                                | 16        |
| <b>Anexos</b>                                                                                                                                    | <b>17</b> |

# Guía de Acciones y Evidencias de Active Directory (TryHackMe Lab)

## Evidencia #1: Usuarios en OU Sales

### Descripción

Al analizar el cuadro, se observa que hay dos personas asignadas al área Sales. Sin embargo, en el Active Directory, dentro de la OU Sales, existen cuatro usuarios (dos cuentas adicionales que no figuran en el esquema empresarial).

### Procedimiento

1. Comparar la lista de usuarios en la OU Sales con el organigrama empresarial.
2. Identificar las cuentas que no corresponden a personas del cuadro.
3. Desactivar las cuentas que no aparecen en el organigrama (las dos cuentas extra).

### Prueba

The image displays an organizational chart and a screenshot of the Active Directory Users and Computers console. The organizational chart shows a hierarchy starting with Daniel, General Manager, under Management. Reporting to Daniel are three departments: Marketing (Mark, Marketing Specialist), Sales (Sophie, Sales Director; Thomas, Sales Rep.), and IT (Phillip, IT Support; Mary, Server Admin; Claire, Domain Admin). The screenshot of the Active Directory Users and Computers console shows the tree view with the Sales department selected. The list of users in the Sales department is as follows:

| Name      | Type | Description |
|-----------|------|-------------|
| Christine | User |             |
| Robert    | User |             |
| Sophie    | User |             |
| Thomas    | User |             |

Below the screenshot, a table lists the names of the users found in the Sales department:

| Name      | Type |
|-----------|------|
| Christine | User |
| Robert    | User |
| Sophie    | User |
| Thomas    | User |

## Evidencia #2: Eliminación de la OU "Research and Development"

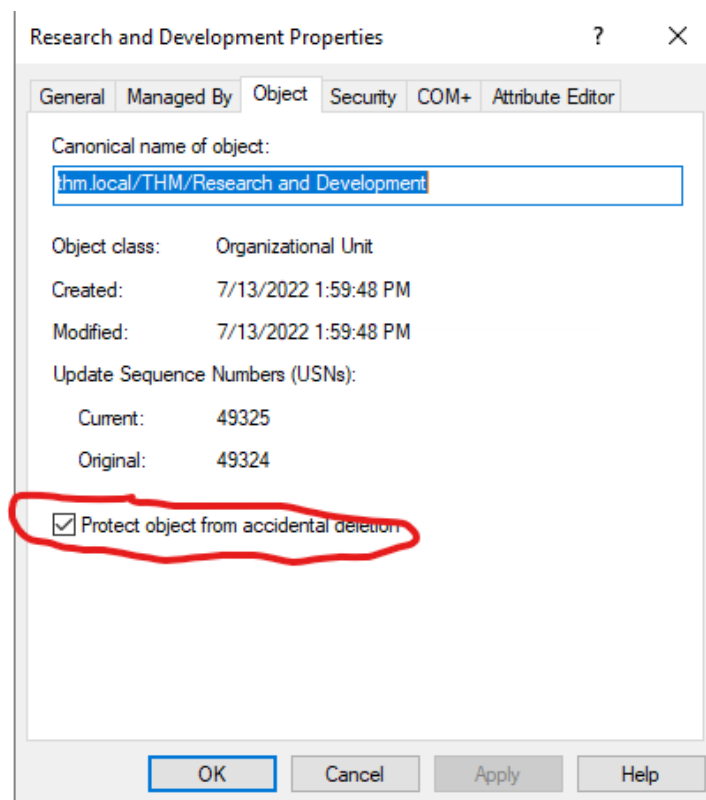
### Descripción

Según las instrucciones del laboratorio (TryHackMe) se debe eliminar la OU Research and Development, pero al intentar borrarla aparece un error.

### Procedimiento

1. Acceder a las propiedades de la OU Research and Development.
2. Revisar y deshabilitar cualquier opción que impida la eliminación de la OU (por ejemplo, la opción que protege la OU contra eliminación o delegaciones pendientes).
3. Guardar los cambios.
4. Intentar nuevamente eliminar la OU.

### Prueba



# Evidencia #3: Delegación de Control y Restablecimiento de Contraseñas

## Descripción

Se delegó la capacidad de Reset user passwords (restablecer contraseñas) a un usuario mediante la función Delegate Control. Aunque el usuario delegado (Phillip) no tiene permisos para abrir la consola de Active Directory Users and Computers, puede cambiar contraseñas mediante PowerShell.

## Procedimiento

1. En la OU correspondiente:
  - a. Ejecutar Delegate Control
  - b. Conceder el permiso Reset User Passwords al usuario designado.
2. Con el usuario delegado (Phillip):
  - a. Iniciar sesión (credenciales: Phillip / Claire2008).
3. Verificar que Phillip no puede abrir la consola gráfica de Active Directory.
4. Mediante PowerShell (con las credenciales de Phillip):
  - a. Ejecutar el comando para restablecer la contraseña del usuario objetivo (por ejemplo, Sophie).
5. Documentar el comando exacto utilizado y el resultado.
6. Verificación final:
  - a. Iniciar sesión con la cuenta de Sophie usando la nueva contraseña (Password123).
  - b. Comprobar el acceso.
7. Localizar el flag en el escritorio de Sophie para confirmar el éxito.

## Prueba

Selected users and groups:

Phillip (phillip@thm.local)

**Tasks to Delegate**  
You can select common tasks or customize your own.

☒ Delegate the following common tasks:

- ☐ Create, delete, and manage user accounts
- ☒ Reset user passwords and force password change at next logon
- ☐ Read all user information

```
PS C:\Users\phillip> Set-ADAccountPassword sophie -Reset -NewPassword (Read-Host -AsSecureString -Prompt 'New Password') -verbose
New Password: *****
VERBOSE: Performing the operation "Set-ADAccountPassword" on target "CN=Sophie,OU=Sales,OU=THM,DC=thm,DC=local1".
PS C:\Users\phillip>
```

Windows Server

Instance Size: 15a.small  
Availability Zones: eu-west-1b  
Architecture: ARM64  
Total Memory: 2048 MB  
Network Performance: Up to 5 GigaBit

Sophie

Windows Administrative tools

Windows Firewall

Windows Security

Windows System

8:12 PM

## Evidencia #4: Organización de Workstations

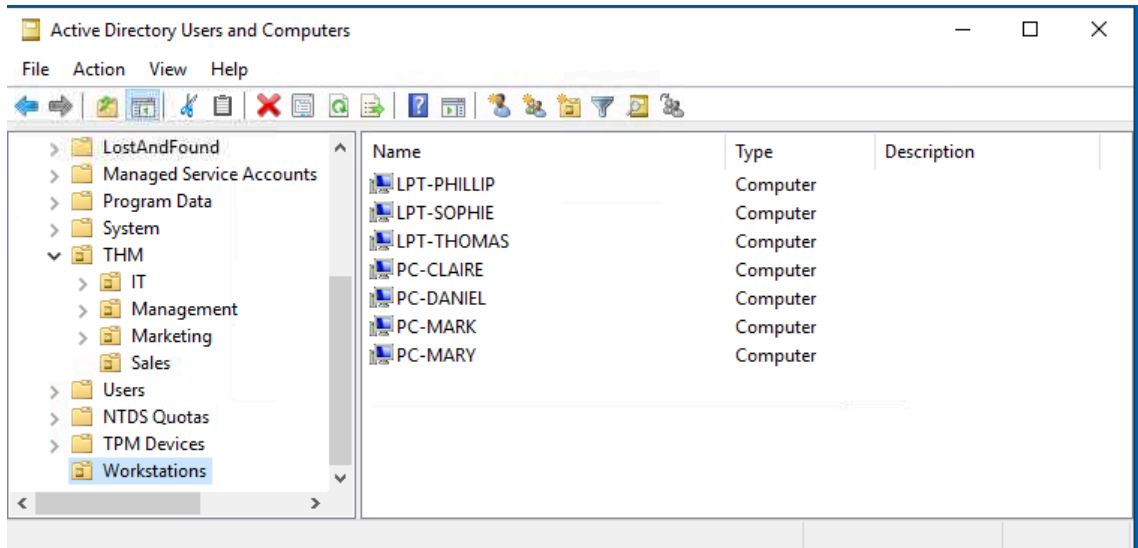
### Descripción

Se creó una OU denominada Workstations y se movieron a ella siete equipos, con el objetivo de aplicar políticas específicas a ese conjunto de equipos.

### Procedimiento

1. Crear la OU Workstations en Active Directory.
2. Seleccionar y mover las siete cuentas de equipo correspondientes a la nueva OU.
3. Verificar

### Prueba



## Evidencia #5: Modificación de GPOs (Group Policy Objects)

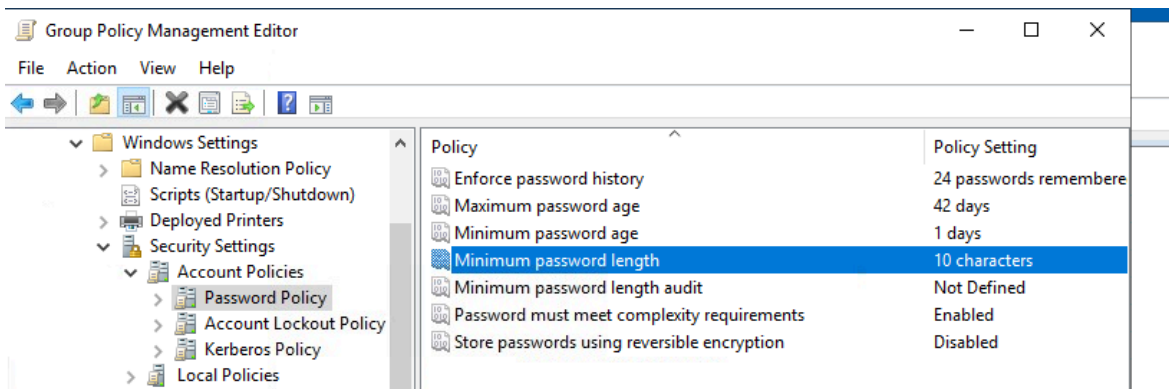
### Descripción

Se modificó una política de contraseñas: se cambió el parámetro Minimum Password Length de 7 a 10 caracteres.

### Procedimiento

1. Abrir el GPO pertinente (por ejemplo, Default Domain Policy o una GPO específica de seguridad).
2. Navegar a la configuración de políticas de contraseñas.
3. Modificar Minimum Password Length de 7 a 10.
4. Forzar la actualización de la política en equipos de prueba (gpupdate /force).
5. Verificar el resultado.

### Prueba





## Evidencia #6: Restricciones y Bloqueo Automático

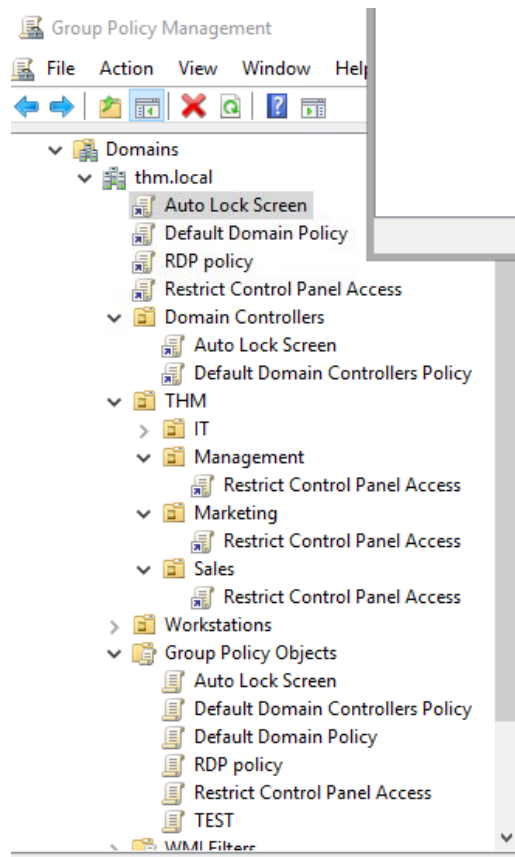
### Descripción y requisitos aplicados

Bloquear el acceso al Control Panel para usuarios que no pertenecen al departamento de TI. Hacer que estaciones de trabajo y servidores bloqueen automáticamente su pantalla tras 5 minutos de inactividad para evitar sesiones expuestas.

### Procedimiento

1. Crear o editar una GPO destinada a usuarios no-IT que contenga la política que restringe el acceso al Panel de Control:
  - a. Configuración:
    - i. User Configuration
    - ii. Administrative Templates
    - iii. Control Panel
    - iv. Prohibit access to Control Panel and PC settings.
2. Aplicar la GPO al grupo o OU que contiene a los usuarios
3. Crear o editar una GPO de seguridad para estaciones y servidores que incluya el bloqueo automático:
  - a. Configuración:
    - i. Computer Configuration
    - ii. Policies
    - iii. Administrative Templates
    - iv. Control Panel
    - v. Personalization
    - vi. Editar: Machine inactivity limit según la versión. Establecer el tiempo de inactividad en 300 segundos.

### Prueba



# Evidencia #7: TryHackMe Completado

|        |                             |     |
|--------|-----------------------------|-----|
| Task 1 | ✔ Introduction              | ▼   |
| Task 2 | ✔ Windows Domains           | ☰ ▼ |
| Task 3 | ✔ Active Directory          | ▼   |
| Task 4 | ✔ Managing Users in AD      | ▼   |
| Task 5 | ✔ Managing Computers in AD  | ▼   |
| Task 6 | ✔ Group Policies            | ▼   |
| Task 7 | ✔ Authentication Methods    | ▼   |
| Task 8 | ✔ Trees, Forests and Trusts | ▼   |
| Task 9 | ✔ Conclusion                | ▼   |

# Preguntas

## 1. ¿Cómo influye la estructura organizacional (OUs, dominios, árboles y bosques) en la seguridad y administración de una red corporativa?

Influye directamente, porque una buena organización permite aplicar políticas claras y delegar permisos de forma segura. Si está mal diseñada, la red se vuelve complicada de manejar y más vulnerable a errores o abusos.

## 2. ¿Cómo puede una mala configuración de delegaciones u OUs dejar expuestos permisos sensibles?

Si se otorgan permisos de más o en lugares equivocados, personas sin la preparación adecuada pueden tener acceso a configuraciones críticas. Esto facilita cambios indebidos o que un atacante lo aproveche para escalar privilegios.

## 3. ¿Qué implicaciones de seguridad surgen al usar diferentes métodos de autenticación como Kerberos vs NTLM en Active Directory?

Kerberos es más seguro porque usa tickets temporales y autenticación mutua, mientras que NTLM se basa en un sistema más antiguo de desafíos que puede ser interceptado y reutilizado.

## 4. ¿Por qué Kerberos es el protocolo preferido hoy en día?

Porque es moderno, más seguro y eficiente. Reduce vulnerabilidades que NTLM ya no puede cubrir y protege mejor el entorno corporativo.

## 5. ¿Qué riesgos existen si NTLM sigue habilitado?

Se pueden explotar técnicas conocidas como pass-the-hash o relay, que permiten a un atacante moverse dentro de la red y comprometer cuentas sensibles.

## 6. ¿Cómo podrían los atacantes aprovechar credenciales o tickets antiguos/vulnerables?

Pueden reutilizar hashes o tickets Kerberos robados (como en un golden ticket) para mantener acceso prolongado y con privilegios altos, sin ser detectados fácilmente.

7. ¿De qué forma las políticas de grupo (GPOs) y su correcta aplicación pueden afectar tanto la productividad como la seguridad de los usuarios?

Las GPOs ayudan a mantener seguridad y orden en los equipos, pero si se aplican mal pueden limitar funciones necesarias y afectar la productividad de los usuarios.

8. ¿Cuándo es beneficioso aplicar políticas muy estrictas vs. políticas más relajadas?

En áreas críticas (como banca o salud) conviene ser muy estricto, mientras que en otras áreas menos sensibles se puede ser más flexible para no frenar el trabajo.

9. ¿Qué consecuencias puede tener aplicar una GPO equivocada (o sin pruebas) a un OU?

Puede bloquear accesos, romper programas o incluso bajar la seguridad sin querer. Por eso siempre es importante probarlas primero en un entorno de prueba.

# Administrador de Directivas de Grupo en Windows

Windows incluye una herramienta muy conocida llamada Administrador de directivas de grupo. Se abre fácilmente escribiendo `gpedit.msc` en la ventana de ejecutar (con la combinación de teclas Windows + R).

Esta utilidad permite configurar políticas de seguridad de forma detallada. Por ejemplo, se pueden definir reglas para la longitud mínima de las contraseñas, establecer caducidad obligatoria cada cierto tiempo, o incluso bloquear el acceso a funciones del sistema que no se deseen para ciertos usuarios.

En un entorno empresarial resulta muy útil, ya que facilita aplicar configuraciones de forma centralizada a muchos equipos, sobre todo cuando se trabaja con Active Directory.

## Herramientas para Deshabilitar Cuentas Predeterminadas o Innecesarias

Algo básico en seguridad es eliminar o desactivar cuentas que no se utilizan. En Windows esto se hace desde la consola de Administración de equipos, en la sección de usuarios y grupos locales. Ahí se selecciona el usuario y se marca la opción de deshabilitar. En Linux se hace por línea de comandos. Por ejemplo, con `usermod -L usuario` se bloquea la cuenta, o con `passwd -l usuario` se evita que esa persona inicie sesión.

En macOS se realiza desde Preferencias del sistema, entrando a Usuarios y grupos, donde se puede borrar o desactivar las cuentas que no hagan falta. Esto es importante porque muchas veces los atacantes aprovechan cuentas predeterminadas, como “guest” o “admin”, para intentar ingresar.

## Políticas de Cuenta y Directivas de Bloqueo de Cuentas

Otra medida muy útil es establecer bloqueos automáticos después de varios intentos fallidos de inicio de sesión. En Windows se configura desde el mismo `gpedit.msc`, en el apartado de Directivas de cuenta. Por ejemplo, se puede indicar que si un usuario falla 5 veces al poner su contraseña, su cuenta se bloquee por 30 minutos.

En Linux se logra con módulos de PAM, como `pam_tally2` o `faillock`, que se configuran en los archivos del directorio `/etc/pam.d/`. Esto obliga a que después de cierta cantidad de intentos la cuenta se bloquee o requiera intervención del administrador. En macOS se utiliza el comando `pwpolicy`, con el que se pueden establecer reglas de seguridad de contraseñas y bloqueos. Estas configuraciones ayudan a evitar ataques de fuerza bruta, que son muy comunes.

# Auditoría y Monitoreo de Cuentas de Usuario

No solo se trata de configurar reglas, también hay que revisar lo que pasa en el sistema. Windows tiene el Visor de eventos, donde se registran todos los intentos de inicio de sesión, tanto los exitosos como los que fallan. Ahí se pueden detectar intentos sospechosos o repetitivos. Linux utiliza archivos de registro como `/var/log/auth.log` o `/var/log/secure`, además de comandos como `last` o `journalctl`, que muestran la actividad de los usuarios.

MacOS también cuenta con registros accesibles desde la aplicación Consola, donde aparecen todos los eventos relacionados con las cuentas y el sistema. Esto sirve para investigar incidentes y tener pruebas en caso de accesos indebidos.

## Gestión de Cuentas Inactivas

Un aspecto que a veces se olvida es qué hacer con las cuentas de usuarios que ya no entran al sistema. En Windows se puede usar PowerShell para buscar cuentas que llevan cierto tiempo sin usarse y luego deshabilitarlas. En Linux existe el comando `lastlog`, que muestra la última vez que un usuario inició sesión. Si nunca se ha iniciado o si ya pasó demasiado tiempo, se puede decidir bloquear esa cuenta.

También se pueden usar configuraciones con `chage` para que la cuenta caduque automáticamente después de un periodo definido. En macOS se pueden manejar cuentas con la herramienta `dscl`, que permite borrar o desactivar usuarios viejos que ya no se necesitan. Mantener cuentas inactivas representa un riesgo, porque alguien podría aprovecharlas si no están vigiladas.

# Reflexión Final

## 1. ¿Qué diferencias notaste en las herramientas disponibles entre los tres sistemas operativos?

Al comparar los tres sistemas operativos, se pueden ver diferencias claras. Windows está muy enfocado en la administración centralizada y facilita mucho el trabajo en empresas gracias a Active Directory y las políticas de grupo. Linux, en cambio, es más flexible y completo a nivel técnico, aunque requiere mayor conocimiento de comandos y configuraciones. macOS tiene un enfoque más sencillo y amigable, con una mezcla de interfaz gráfica y comandos en terminal, pero es un poco más limitado que los otros dos.

## 2. ¿Qué sistema operativo consideras más completo para gestionar y auditar cuentas de usuario? Justifica tu respuesta.

En mi opinión, Windows es el más completo para ambientes corporativos, porque permite un control total de las cuentas y políticas desde un mismo lugar, algo que en organizaciones grandes es muy necesario.

## 3. ¿Qué otros pasos podrías implementar para complementar la seguridad de las cuentas de usuario?

Para complementar la seguridad de las cuentas, además de lo explicado, sería recomendable aplicar autenticación multifactor, revisar permisos periódicamente, eliminar usuarios que ya no trabajen en la empresa y capacitar al personal sobre el uso seguro de contraseñas.

# Anexos

- **Anexo A:** Evidencias gráficas: capturas de pantalla de usuarios, OUs, GPOs y resultados de pruebas.
- **Anexo B:** Comandos utilizados: Set-ADAccountPassword -Identity "Sophie" -Reset -NewPassword (ConvertTo-SecureString "Password123" -AsPlainText -Force).
- **Anexo C:** Listas y comparaciones: usuarios en organigrama vs usuarios en AD, equipos y OUs, políticas GPO antes y después de cambios.